

Cyber Threat Intelligence

Executive Briefing

Report Date: July 02, 2026

Generated: 2026-07-02 02:36 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
5	10	5	0	20

2. Executive Summary

As of July 02, 2026, the security operations center has completed the analysis of 20 total vulnerabilities, categorized as 5 Critical, 10 High, 5 Medium, and 0 Low severity findings. This volume of critical and high-severity exposures indicates an elevated organizational risk posture, necessitating immediate remediation to maintain a secure operating environment consistent with CVSS v3.1 industry standards. The primary threat requiring urgent intervention is CVE-2026-53943, Cache Poisoning XSS in Ghost Frontend, due to its potential for weaponization in high-impact cross-site scripting campaigns that compromise user session integrity. Our current posture must shift to an immediate remediation and containment phase to preempt potential exploitation of these architectural weaknesses. We recommend the prompt deployment of identified patches and infrastructure hardening measures to mitigate these vectors of attack before they are leveraged by adversarial actors.

3. Critical Action List

1. Immediately patch the Ghost frontend to remediate CVE-2026-53943 and prevent cache-poisoning XSS attacks within 24 hours.
2. Execute an emergency update of the Rancher deployment environment to sanitize YAML parameters and resolve the CVE-2026-44939 command injection vulnerability within 24 hours.
3. Disable affected GitHub App authentication providers to neutralize CVE-2026-41053, ensuring membership expansion is re-validated within 48 hours.
4. Restrict Helm chart references in Rancher Fleet and apply relevant security patches to mitigate the CVE-2026-44935 secret disclosure risk within 48 hours.
5. Implement strict API boundary controls within Rancher to prevent project owner host-level privilege escalation associated with CVE-2026-41052 by close of business, July 4, 2026.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-53943	Cache Poisoning XSS in Ghost Fron...	9.6	Critical	96/100	CWE-524
CVE-2026-44939	Command Injection in Rancher YAML	10.0	Critical	96/100	CWE-95
CVE-2026-41053	Rancher GitHub Auth Membership Ex...	8.8	High	89/100	CWE-303
CVE-2026-44935	Rancher Fleet Secret Disclosure	10.0	Critical	89/100	CWE-863
CVE-2026-41052	Rancher Project Owner Host Escala...	7.2	High	86/100	CWE-305
CVE-2026-49457	QUIC Broken TLS Verification	9.8	Critical	82/100	CWE-295
CVE-2026-44938	PSS Bypass via Fleet Agent	9.8	Critical	79/100	CWE-522
CVE-2026-9795	Keycloak Privilege Escalation via...	7.3	High	76/100	CWE-266
CVE-2026-50143	Token Leak via MCP Authority Inje...	7.5	High	73/100	CWE-918
CVE-2026-50138	WebDAV Listener Mode Bypass	7.5	High	73/100	CWE-284
CVE-2026-53712	SCRAM Authentication Downgrade Vu...	7.4	High	68/100	CWE-636
CVE-2026-50151	Credential Forwarding in oras-go ...	7.5	High	68/100	CWE-918
CVE-2026-44937	Regex Injection in Fleet Webhook	7.5	High	68/100	CWE-345
CVE-2026-50163	Relative Linkname Traversal in or...	8.6	High	64/100	CWE-22
CVE-2026-48978	Bearer Token Realm Hijacking in o...	7.3	High	59/100	CWE-319
CVE-2026-50139	Race Condition in File Token Rede...	5.6	Medium	53/100	CWE-362
CVE-2026-50162	Write Outside WorkingDir via Syml...	5.5	Medium	50/100	CWE-73
CVE-2026-48824	Mailpit Sibling-Endpoint Memory D...	5.3	Medium	48/100	CWE-770
CVE-2026-44936	SSRF in Rancher Fleet Bundle Read...	4.3	Medium	45/100	CWE-918
CVE-2026-48819	Prototype Chain Substitution in O...	6.5	Medium	43/100	CWE-1321

5. Detailed Vulnerability Findings

CVE-2026-53943

Finding: Cache Poisoning XSS in Ghost Frontend

CVSS v3.1 Score: 9.6 | Severity: Critical | Urgency Score: 96/100 | CWE: CWE-524

MITRE ATT&CK: T1189, T1505

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

Ghost frontend is susceptible to a cache-poisoning cross-site scripting (XSS) attack via the x-ghost-preview header. The vulnerability occurs because the application improperly reflects header contents in the response without adequate sanitization or cache partitioning. This enables attackers to inject malicious scripts that execute in the browser of other

users, compromising their session confidentiality.

Proof of Concept (PoC):

An unauthenticated remote attacker crafts a request including a malicious payload in the x-ghost-preview header and sends it to the Ghost frontend. The server-side cache stores the response containing the payload and serves it to subsequent legitimate users. When a victim accesses the page, the browser interprets the injected script as trusted content. This results in the execution of arbitrary JavaScript within the user's session context.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53943>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53943>

CVE-2026-44939

Finding: Command Injection in Rancher YAML

CVSS v3.1 Score: 10.0 | Severity: Critical | Urgency Score: 96/100 | CWE: CWE-95

MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Rancher is vulnerable to command injection through the processing of unsanitized YAML parameters within its deployment controller. The failure occurs in the parsing logic that executes system-level commands based on specific YAML keys. An attacker can craft a YAML payload that includes shell command syntax, leading to arbitrary code execution with the permissions of the Rancher process.

Proof of Concept (PoC):

An attacker submits a specially crafted YAML configuration file to a target Rancher instance via an API endpoint. The parser incorporates an attacker-supplied parameter directly into a system-level command executed via shell. The command is executed by the server, allowing the attacker to bypass system controls. This results in full system compromise and unauthorized command execution on the host machine.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44939>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44939>

CVE-2026-41053

Finding: Rancher GitHub Auth Membership Expansion

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 89/100 | CWE: CWE-303

MITRE ATT&CK: T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High

Integrity Impact

High

Availability Impact

High

Description:

Rancher exhibits over-inclusive team membership expansion within its GitHub App authentication provider. The vulnerability occurs because the provider fails to verify nested team depth and scope during the sync process, granting excessive access. An attacker with partial team membership can gain unauthorized privileges over the organization's projects and assets.

Proof of Concept (PoC):

An authenticated user with low-level GitHub team membership initiates an authentication flow via the Rancher GitHub App. The sync engine improperly resolves the user's total group membership, failing to respect the intended security boundaries of the organization. As a result, the user is assigned higher-level access permissions within Rancher that are tied to different, more privileged teams. This allows the attacker to perform unauthorized operations.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-41053>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-41053>

CVE-2026-44935**Finding: Rancher Fleet Secret Disclosure**

CVSS v3.1 Score: 10.0 | Severity: Critical | Urgency Score: 89/100 | CWE: CWE-863

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Rancher Fleet is vulnerable to cross-namespace secret disclosure through unvalidated `valuesFrom` references in the Helm Deployer. The root cause is the lack of authorization checks when resolving secret references across Kubernetes namespaces. An attacker can create a fleet deployment that points to secrets in restricted namespaces, resulting in their unauthorized disclosure.

Proof of Concept (PoC):

An unauthenticated remote attacker creates a `fleet.yaml` manifest containing a `valuesFrom` secret reference that points to a target namespace (e.g., 'kube-system'). The Rancher Fleet agent processes the deployment and fetches the requested secret from the unauthorized namespace. The sensitive information is then rendered into the deployment context or logs accessible to the attacker. This results in the complete disclosure of critical infrastructure secrets.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44935>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44935>

CVE-2026-41052**Finding: Rancher Project Owner Host Escalation**

CVSS v3.1 Score: 7.2 | Severity: High | Urgency Score: 86/100 | CWE: CWE-305

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Rancher contains a flaw where a project owner can escalate privileges to host-level access due to insecure API boundary enforcement. The issue stems from an incorrect trust model regarding the permissions granted to project-scoped entities when interacting with the underlying Kubernetes host. An attacker with project-level ownership can bypass these restrictions to gain full administrative control over the underlying host node.

Proof of Concept (PoC):

An authenticated user with Project Owner privileges sends a malicious request to the Rancher management API targeting host-level resources. The API layer fails to properly validate the user's project-scope against the requested host resource. The controller then executes the request using the Rancher system's elevated credentials on the underlying Kubernetes node. This results in the attacker achieving full administrative control over the infrastructure host.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-41052>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-41052>

CVE-2026-49457**Finding: QUIC Broken TLS Verification**

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-295

MITRE ATT&CK: T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The QUIC implementation contains a vulnerability involving broken TLS certificate verification. The issue arises from a failure to correctly validate the certificate chain and hostname during the connection handshake. This allows an attacker to perform man-in-the-middle attacks, intercepting and decrypting encrypted traffic without being detected by the endpoints.

Proof of Concept (PoC):

A network-positioned attacker intercepts the initial QUIC handshake between a client and a server. The attacker presents a fake, self-signed certificate during the TLS verification stage. The QUIC implementation fails to validate the certificate's authenticity, wrongly trusting the connection. This results in the attacker successfully establishing a man-in-the-middle position and accessing all data transmitted over the connection.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49457>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49457>

CVE-2026-44938

Finding: PSS Bypass via Fleet Agent

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 79/100 | CWE: CWE-522

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Fleet agent is vulnerable to a Pod Security Standard (PSS) bypass through the `addLabelsFromOptions` function. The vulnerability is caused by the lack of proper validation when merging label configurations, allowing attackers to inject restricted labels that bypass security policies. This enables the deployment of pods that violate the hardened security standards configured for the cluster.

Proof of Concept (PoC):

An attacker submits a configuration to the Fleet agent that includes specifically crafted labels designed to be processed by the `addLabelsFromOptions` method. The function incorrectly merges these labels, causing the agent to misidentify or bypass the configured PSS constraints for the pod. Consequently, the agent deploys a pod with restricted capabilities or configuration that should have been prohibited. This leads to a security policy violation on the target cluster.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44938>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44938>

CVE-2026-9795

Finding: Keycloak Privilege Escalation via Scopes

CVSS v3.1 Score: 7.3 | Severity: High | Urgency Score: 76/100 | CWE: CWE-266

MITRE ATT&CK: T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:R/S:C/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	High
Scope	Changed
Integrity Impact	High

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

Description:

Keycloak suffers from a privilege escalation vulnerability resulting from improper enforcement of scope mapping in authorization policies. The flaw exists in the core authorization engine which fails to strictly validate user claims against mapped scopes during token issuance. An attacker can exploit this to gain elevated permissions, granting unauthorized access to restricted resources.

Proof of Concept (PoC):

An authenticated administrator with restricted access sends a token request for specific scopes. The attacker manipulates the request parameters to include scopes that should be restricted to super-users. Keycloak improperly

validates these scopes against the user's role mapping and issues a token with escalated privileges. This allows the attacker to access administrative functions that they should not be permitted to use.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-9795>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-9795>

CVE-2026-50143

Finding: Token Leak via MCP Authority Injection

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 73/100 | CWE: CWE-918

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Apify Model Context Protocol server suffers from a path authority injection vulnerability within the Actor MCP implementation. This flaw arises from insufficient validation of path inputs, allowing attackers to manipulate internal request routing. Exploitation results in the unauthorized disclosure of sensitive Apify tokens to an external entity.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a crafted MCP request with a modified authority field to the server. The server processes the malformed path without verifying the integrity of the destination authority. The underlying logic then routes sensitive credential data toward an attacker-controlled endpoint. This allows the attacker to intercept and exfiltrate the Apify authentication token.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50143>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50143>

CVE-2026-50138

Finding: WebDAV Listener Mode Bypass

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 73/100 | CWE: CWE-284

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The goshs WebDAV listener fails to enforce security mode flags such as --read-only, --upload-only, and --no-delete. The root cause is a failure in the configuration parser to pass these flags to the WebDAV handler logic at runtime. This allows unauthorized users to perform file operations that should be restricted, leading to significant integrity risks.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies a WebDAV instance configured in --read-only mode. The attacker submits a DELETE or PUT request to the WebDAV endpoint instead of a GET request. The server fails to validate the request against the intended mode restrictions, allowing the deletion or upload of files. This leads to unauthorized modification or destruction of system data.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50138>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50138>

CVE-2026-53712**Finding: SCRAM Authentication Downgrade Vulnerability**

CVSS v3.1 Score: 7.4 | Severity: High | Urgency Score: 68/100 | CWE: CWE-636

MITRE ATT&CK: T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

OnGres SCRAM authentication implementation allows for a silent channel-binding downgrade due to support for insecure certificate algorithms. The failure occurs during the negotiation phase where the server accepts lower-strength algorithms without enforcing secure defaults. This exposes authentication exchanges to potential interception and credential brute-forcing by a man-in-the-middle attacker.

Proof of Concept (PoC):

A network-positioned attacker intercepts the initial SCRAM handshake between the client and the OnGres server. The attacker strips out high-security certificate algorithm proposals, forcing the connection to downgrade to a weaker, unsupported algorithm. The server unknowingly accepts the downgraded parameter and proceeds with authentication using weakened security measures. This allows the attacker to capture and analyze the authentication exchange to recover credentials.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53712>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53712>

CVE-2026-50151**Finding: Credential Forwarding in oras-go Blob Upload**

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-918

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The oras-go blob upload component is vulnerable to credential forwarding due to the failure to validate the Location header during redirects. The software blindly follows the Location header provided by the server, which can be manipulated to point to an attacker-controlled host. This allows an attacker to intercept the authorization credentials sent by the client during the redirect process.

Proof of Concept (PoC):

An attacker hosts a malicious container registry that triggers an HTTP 302 redirect upon receiving an oras-go blob upload request. The registry sets the Location header to an attacker-controlled endpoint. When the oras-go client follows the redirect, it inadvertently includes the original bearer token or sensitive authentication headers in the request to the attacker's server. This grants the attacker unauthorized access to the victim's credentials.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50151>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50151>

CVE-2026-44937**Finding: Regex Injection in Fleet Webhook**

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-345

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

Rancher Fleet contains a regex injection vulnerability in its unauthenticated webhook endpoint due to unsanitized repository URL components. This flaw allows an attacker to manipulate the internal regular expression used to validate or filter incoming requests. Exploitation can lead to bypasses of intended security logic and potential unauthorized resource access.

Proof of Concept (PoC):

An attacker crafts a malicious webhook payload containing a repository URL that includes regex control characters. The webhook processor incorrectly appends this input into a regex filtering routine. By providing a crafted payload, the attacker effectively disables or alters the regex filter, allowing malicious requests to pass through validation. This results in the potential bypassing of access control mechanisms protected by the regular expression.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44937>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44937>

CVE-2026-50163**Finding: Relative Linkname Traversal in oras-go**

CVSS v3.1 Score: 8.6 | Severity: High | Urgency Score: 64/100 | CWE: CWE-22

MITRE ATT&CK: T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

The oras-go tar extraction utility improperly handles hardlink entries containing relative Linknames during process CWD resolution. This vulnerability stems from failing to restrict extraction paths to the intended target directory, allowing directory traversal. An attacker can create a malicious tar archive that overwrites critical files on the host system outside of the extraction root.

Proof of Concept (PoC):

An attacker creates a malicious tar file containing a hardlink entry with a Linkname that points to a path like '.././../etc/passwd'. The attacker provides this archive to a user who executes the oras-go extraction tool. The tool resolves the relative path incorrectly and extracts the file into the sensitive directory on the host. This results in the overwriting of configuration files and unauthorized system-level file manipulation.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50163>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50163>

CVE-2026-48978

Finding: Bearer Token Realm Hijacking in oras-go

CVSS v3.1 Score: 7.3 | Severity: High | Urgency Score: 59/100 | CWE: CWE-319

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

The oras-go library is vulnerable to bearer token realm hijacking because it fails to validate the registry realm during authentication, leading to credential exfiltration. The application uses untrusted registry responses to define the authentication scope for subsequent requests. This allows a malicious registry to redirect authentication traffic to an attacker-controlled endpoint and capture sensitive refresh tokens.

Proof of Concept (PoC):

An attacker sets up a rogue container registry that, when queried by oras-go, returns a custom 'Www-Authenticate' header specifying an attacker-controlled authentication realm. The client library parses this header and initiates the authentication flow against the attacker's provided URL. The user unknowingly submits their credentials to the attacker's server as part of the expected authentication handshake. This results in the compromise of the user's registry credentials.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48978>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48978>

CVE-2026-50139

Finding: Race Condition in File Token Redemption

CVSS v3.1 Score: 5.6 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-362

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

The goshs application contains a race condition in the share-link token redemption function. This vulnerability stems from a lack of atomic locking mechanisms when checking and decrementing download limits against the current session count. An attacker can exploit this to exceed configured file download limits, impacting resource availability and system integrity.

Proof of Concept (PoC):

An unauthenticated remote attacker initiates multiple concurrent requests using the same token via the share-link download endpoint. The server checks the remaining download count for each request simultaneously before the first request finishes decrementing the database counter. Because the check-and-set operations are non-atomic, the server permits more downloads than allowed. This allows the attacker to bypass the system's usage restrictions.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50139>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50139>

CVE-2026-50162

Finding: Write Outside WorkingDir via Symlinks

CVSS v3.1 Score: 5.5 | Severity: Medium | Urgency Score: 50/100 | CWE: CWE-73

MITRE ATT&CK: T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	None

Description:

The oras-go file store allows writing data outside the specified working directory by failing to validate symlink traversal. The issue arises from the program's reliance on file paths provided within an archive without verifying their resolution within the target directory. An attacker could exploit this to perform arbitrary file writes, potentially modifying sensitive system or application data.

Proof of Concept (PoC):

An attacker prepares a package archive containing a symlink entry that points to a target path like '/etc/cron.d/malicious_job'. When a target user triggers an oras-go pull or write operation using this archive, the client

processes the symlink as part of the extraction. The write operation follows the symlink, placing attacker-supplied data into a system-controlled file. This results in unauthorized modification of host configuration files.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50162>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50162>

CVE-2026-48824

Finding: Mailpit Sibling-Endpoint Memory DoS

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-770

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

Mailpit is vulnerable to a memory-exhaustion denial of service attack via unbounded JSON body processing in its API endpoints. The failure occurs in the handler for /api/v1/messages and related paths which do not properly bound the size of incoming JSON requests. An attacker can send excessively large payloads to exhaust server memory, leading to a service disruption.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a POST request with an extremely large, deeply nested JSON body to the /api/v1/messages endpoint. The server attempts to allocate memory to buffer and process the payload without checking the total input size. This leads to excessive memory consumption, causing the application to crash or become unresponsive to other users. The service availability is severely degraded as a result.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48824>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48824>

CVE-2026-44936

Finding: SSRF in Rancher Fleet Bundle Reader

CVSS v3.1 Score: 4.3 | Severity: Medium | Urgency Score: 45/100 | CWE: CWE-918

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Rancher Fleet is susceptible to a server-side request forgery (SSRF) vulnerability in the bundle reader. This is caused by the lack of input validation on the Helm repository URL provided within the `fleet.yaml` file. An attacker can force the

Fleet agent to make requests to arbitrary internal or external network resources.

Proof of Concept (PoC):

An authenticated user creates a `fleet.yaml` manifest specifying a malicious Helm repository URL that points to an internal resource (e.g., `http://169.254.169.254/latest/meta-data/`). The Fleet bundle reader attempts to connect to this URL to fetch chart information. The server performs the request on the attacker's behalf, leaking sensitive metadata or allowing the attacker to probe the internal network. This results in the breach of internal network information.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44936>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44936>

CVE-2026-48819

Finding: Prototype Chain Substitution in OpenAPI-TS

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 43/100 | CWE: CWE-1321

MITRE ATT&CK: T1195

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	Low	Availability Impact	None

Description:

@hey-api/openapi-ts is susceptible to prototype chain substitution within its `buildClientParams` template. The issue arises from the insecure handling of object keys, specifically when an attacker-controlled key includes the `__proto__` slot. This allows an attacker to inject properties into the global object prototype, potentially resulting in downstream application logic vulnerabilities.

Proof of Concept (PoC):

An attacker provides a malicious OpenAPI definition containing a custom parameter name formatted as ``${slot}__proto__``. The OpenAPI-TS builder processes this definition and inadvertently sets this key on the object prototype during the `buildClientParams` template execution. Subsequent code within the generated client will now access the injected prototype property instead of the expected instance value. This leads to potential logic flow redirection or unauthorized state modification.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48819>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48819>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official

databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>